

Findings and ablation

Corrected hash-rule edition | 30 September 2026 | Saved-evidence recomputation; no new scans or model calls

Main conclusion: ProvTrail can recognize code matching known vulnerable implementations even when the source package is not declared as a dependency. This complements the tested SAST and dependency-SCA configurations. The experiments do not establish application exploitability or detection of novel vulnerabilities.

Recommended operating point

K5/B10, R96/V3, containment OFF, hashing ON, contrastive scoring ON, LLM OFF. Structure/token thresholds 0.70; edit-side threshold 0.90; margin 0.10. CUDA FP32 embeddings with the frozen CPU reference index. This is a supported balance among tested settings, rather than a proven global optimum.

Revision: exact hashes determine the fix side when abstracted hashes match both sides. Abstracted-only ambiguity remains for review without a contradiction label. Quality is recomputed from preserved evidence; timing and repetition claims describe the original runs.

Report section	Primary evidence	What it establishes
Main findings	600 release-source + 600 transformed cases	Known-origin recognition, attribution, false alerts and abstention
Parameter ablation	38 CPU tuning settings; 4 evaluation settings; 3 GPU repetitions	Sensitivity to thresholds, K, budgets and region caps
Component ablation	4 settings x 1,200 cases x 3 GPU repetitions	Contribution of hashing, contrastive scoring and containment
Containment stress test	100 designed cases; on/off; 3 repetitions	No aggregate detection gain; exposes benign review burden
Tool comparison	10 advisories, SAST metadata arms, SCA declared/copy arms	Complementary coverage when copied code lacks package declarations
LLM review	119 selected-boundary reviews; completed local/hosted studies	Recall, false-alert and dismissal tradeoffs

How to use this document

Use pages 2-7 for the main findings and ablation tables. Page 8 gives reporting limits and an evidence map. Pages 9-10 list every CPU tuning configuration. Keep denominators and workload conditions visible when copying tables.

Counting: the main cohort contains 601 vulnerable and 599 patched cases. Repetitions establish stability and timing; they do not increase the number of independent quality examples. The tool comparison contains ten advisory units, with correlated original/renamed variants.

Main detector findings

K5/B10 with containment OFF | Corrected quality replay; original GPU timing retained

Metric	Tier 1: release source	Tier 2: transformed	Combined
Automatic vulnerable recall	300/300 (100.00%)	264/301 (87.71%)	564/601 (93.84%)
Correct-origin automatic recall	300/300 (100.00%)	259/301 (86.05%)	559/601 (93.01%)
Automatic precision	300/313 (95.85%)	264/283 (93.29%)	564/596 (94.63%)
Patched false-alert rate	13/300 (4.33%)	19/299 (6.35%)	32/599 (5.34%)
Manual-review abstention	0/600 (0.00%)	118/600 (19.67%)	118/1200 (9.83%)
Vulnerable abstention	0/300 (0.00%)	37/301 (12.29%)	37/601 (6.16%)
Patched abstention	0/300 (0.00%)	81/299 (27.09%)	81/599 (13.52%)

Retrieval and automatic decisions measure different things

Hybrid retrieval	Tier 1	Tier 2
Recall@1	100.00%	70.00%
Recall@5	100.00%	95.33%
Recall@10	100.00%	99.00%
MRR	1.0000	0.8095

All 601 vulnerable-labelled cases reached an automatic alert or manual review. This is **routing coverage**, not 100% automatic detection or correct-advisory attribution. Five automatic positives lacked a correct-origin vulnerable verdict.

The corrected queue contains **596 automatic alerts** (564 vulnerable-labelled, 32 patched-labelled) and **118 reviews**. The Next.js tuning case changes from review to an exact vulnerable-side finding; all other main-cohort verdicts are unchanged. Automatic patched disposition remains 486/599. Original median detector time: **349.413 seconds (5.82 minutes)**; revised runtime has not been measured.

Interpretation for the report

Release-source correct-origin automatic recall is now **300/300 (100%)**, versus 86.05% on transformed candidates. This is performance against advisory-labelled known-origin cases, not proof of exploitability. Report abstentions alongside recall rather than quoting conditional recall alone.

Evidence: eval/comparison_raw/hash-rule-summary-v1/operating-point-summary.json and active-component-ablation-gpu-v1/summary.json; original runs remain under eval/frozen/.

Parameter ablation

CPU tuning/evaluation followed by GPU validation of four independent alternatives

Original runs: **38 CPU settings x 359 tuning cases**; four settings x **841 evaluation cases**; three full-cohort GPU repetitions per shortlisted setting. The corrected replay changes one Tier 1 tuning case in every hash-enabled setting. All parameter evaluation-partition outcomes are unchanged. The grouped split is retrospective, not a pristine holdout.

GPU evaluation: the 422 transformed-clone cases

Setting	Auto recall	Origin recall	Patched FPR	Reviews / 422
Baseline	183/210 (87.14%)	178/210 (84.76%)	13/212 (6.13%)	88
S0.80	181/210 (86.19%)	176/210 (83.81%)	13/212 (6.13%)	82
R64	183/210 (87.14%)	174/210 (82.86%)	12/212 (5.66%)	87
K5/B10	183/210 (87.14%)	178/210 (84.76%)	13/212 (6.13%)	92

Tier 1 evaluation is identical in all four: 210/210 vulnerable detections, 7/209 patched false alerts and zero abstentions. Hash recognition makes this tier insensitive to the tested region controls.

GPU timing: full 1,200-case passes

Setting	Seconds: repeats 1 / 2 / 3	Median	Change vs baseline
Baseline	498.1, 394.7, 457.4	457.4s	+0.0%
S0.80	494.7, 461.2, 466.6	466.6s	+2.0%
R64	352.9, 313.3, 343.9	343.9s	-24.8%
K5/B10	488.2, 407.8, 447.5	447.5s	-2.2%

K5/B10: preserves evaluation detection/error counts with four extra reviews; the full-cohort GPU speed difference is only about 2%. **S0.80**: six fewer reviews but two fewer correct detections and no evaluation FP reduction. **R64**: about 25% faster, but four fewer net correct-origin detections and one fewer FP. These alternatives were not combined.

CPU evaluation showed the same origin/FP tradeoffs, but single-pass speed reductions were larger (K5 about 19%; R64 about 38%). Do not transfer those percentages to GPU. GPU repeats reproduced decisions/ranks. Each setting differs from its CPU counterpart in 131-139 tracked cases, mainly intermediate ranks/evidence; K5 also changes one priority/abstention.

Evidence: Recomputed quality:
eval/comparison_raw/hash-rule-summary-v1/active-{tuning-v2,evaluation-shortlist-v2,shortlist-gpu-v1}/summary.json. Timings and CPU/GPU parity are original frozen measurements.

Component ablation

K5/B10 control, containment ON | Corrected quality replay of one-component removals

Tier 1: 300 vulnerable + 300 patched

Setting	Auto recall	Origin recall	Patched FPR	Reviews / 600
control	300/300 (100.00%)	300/300 (100.00%)	13/300 (4.33%)	0
no hash	276/300 (92.00%)	269/300 (89.67%)	28/300 (9.33%)	146
no containment	300/300 (100.00%)	300/300 (100.00%)	13/300 (4.33%)	0
no contrastive	300/300 (100.00%)	300/300 (100.00%)	13/300 (4.33%)	0

Tier 2: 301 vulnerable + 299 patched

Setting	Auto recall	Origin recall	Patched FPR	Reviews / 600
control	264/301 (87.71%)	259/301 (86.05%)	19/299 (6.35%)	128
no hash	258/301 (85.71%)	250/301 (83.06%)	23/299 (7.69%)	161
no containment	264/301 (87.71%)	259/301 (86.05%)	19/299 (6.35%)	118
no contrastive	241/301 (80.07%)	231/301 (76.74%)	19/299 (6.35%)	188

What each removal demonstrates

Remove hashing: corrected Tier 1 origin detections fall 300 to 269, patched alerts rise 13 to 28, and reviews rise 0 to 146. The no-hash run itself is unchanged. Tier 2 origin detections fall 259 to 250. Hash recognition is a substantial contributor, especially for release-source reuse.

Remove contrastive scoring: Tier 2 correct-origin detections fall 259 to 231 and reviews rise 128 to 188; patched alerts remain 19. Comparing vulnerable and patched fix-side evidence contributes to automatic discrimination on transformed candidates.

Remove containment: automatic detection and patched-alert counts remain unchanged. Tier 2 reviews fall 128 to 118, with Tier 1 unchanged. This directly tests the recommended **K5/B10 + containment OFF** combination; it is not inferred by merging separate parameter results.

Timing caveat

Median full-pass detector times: control 318.6s; no hash 1,029.3s; no containment 349.4s; no contrastive 334.3s. The component batches ran under different conditions, and one no-hash repetition spans an interruption. These timings support workload observations, but do **not** establish that disabling containment speeds up the full cohort. The targeted study on page 5 is the cleaner containment timing comparison.

Evidence: eval/comparison_raw/hash-rule-summary-v1/active-component-ablation-gpu-v1/summary.json and changes.json. First-pass quality replay; original study had three repetitions per setting. Historical timings retained.

Containment and review burden

Designed 100-case stress test | Ten advisory origins | Three repetitions per setting

The stress set contains 40 vulnerable clones, 40 patched clones and 20 unrelated benign controls. It includes prefix/distributed additions and exact/rename controls. It is exploratory and designed to challenge containment; it is not a representative deployment sample.

Metric	Containment ON	Containment OFF
Automatic vulnerable recall	32/40 (80.00%)	32/40 (80.00%)
Correct-origin recall	31/40 (77.50%)	31/40 (77.50%)
Patched false alerts	3/40 (7.50%)	3/40 (7.50%)
Benign automatic alerts	0/20	0/20
Total manual reviews	34/100	34/100
Benign manual reviews	20/20	20/20
Median detector time	60.843s	55.363s

Containment OFF was about **9% faster** here, with unchanged aggregate detection and false alerts. One case enters review and one leaves it, so equal review totals do not imply identical dispositions. Thirteen forced whole-function correspondence checks were rescued diagnostically; these were not additional final vulnerability detections.

Main-cohort conflict audit

Observation at the final operating point	Count	Interpretation
Patched reviews already marked patched at expected boundary	45/81	Another uncertain boundary kept the case in review
Patched false alerts already marked patched at expected boundary	30/32	Another boundary produced an automatic alert
Vulnerable automatic alerts without correct-origin verdict	5	Binary alerting overstates correct attribution

Report finding: containment provided no observed aggregate detection benefit in these tested workloads. Disabling it preserves quality and can reduce unnecessary abstentions. Avoid concluding that containment never helps, or that zero benign automatic alerts implies zero workload: every benign control still required review.

Next improvement: audit fix-boundary attribution and conflicting evidence. A case labelled patched for one advisory may contain another genuine issue; do not automatically treat every additional-boundary alert as a confirmed false positive.

Evidence: [eval/frozen/containment-targeted-100-gpu-v1/combined/tables.md](#); [active-component-ablation-gpu-v1/combined/operating-point-review.md](#) and [operating-point-case-audit.json](#).

SAST and dependency-SCA findings

Ten advisories across five packages | Same exact-copy and local-rename targets across paired arms

SAST: target-overlapping alerts

Tool	Vulnerable: no metadata	Vulnerable: metadata added	Patched: both arms
ProvTrail	20/20	20/20	0/20
Semgrep Code	2/20	2/20	2/20
CodeQL	0/20	0/20	0/20

Semgrep target alerts concern Validator rtrim custom-character regex handling; the selected advisory fixes default whitespace trimming. They persist on the patched variants. Therefore overlap is not intended-issue detection. CodeQL has background warnings, including related Vite access paths; zero target-overlap detections does not mean zero findings or no related coverage.

Adding authentic upstream metadata (40 manifests; 20 available lockfiles) changes no selected-target outcome. It adds 28 Semgrep configuration warnings and four CodeQL background regex warnings. The conservative count of advisories with no SAST alerts anywhere falls from **6/10 to 3/10**. Installed dependencies and complete applications were not added.

SCA: declared versions versus undeclared copied implementations

Input condition	Semgrep Supply Chain	OSV-Scanner	ProvTrail
Declared vulnerable package	10/10	10/10	N/A: source absent
Declared fixed package	0/10	0/10	N/A: source absent
Copied vulnerable; package undeclared	0/20	0/20	20/20
Copied patched; package undeclared	0/20	0/20	0/20

Both SCA tools identified all declared package/version controls and read the valid empty inventories in copied projects. Reachable, unreachable and no-reachability-analysis findings all counted; the misses were not caused by an exploitability filter. This demonstrates a dependency-inventory coverage boundary for the tested configurations.

Scope: the 20 vulnerable variants are ten exact reference copies and ten local renames. All ProvTrail detections used exact/abstracted hashes, with no embedding retrieval needed. There were 5,166 manual-review records across the 40 snapshots; these are workload, not confirmed false positives. Five advisories concern Undici. No external holdout or application exploitability claim follows.

Semgrep 1.177.0 used the available Pro cross-file engine and saved account policy; CodeQL 2.27.0 used security-extended; OSV-Scanner 2.6.0 used verified lockfile scans. Fresh Semgrep controls passed 12/12 unsafe and 12/12 safe sinks. No generative AI actions or findings uploads were requested.

Evidence: eval/comparison_raw/sast-ten-v1/RESULTS.md; sast-ten-dependencies-v1/RESULTS.md; sca-copy-v1/RESULTS.md and verification.json.

LLM review and clone sensitivity

Reprojected saved reviews | No new model calls; no new latency or cost measurements

The corrected baseline leaves **118 reviews** (37 vulnerable-labelled, 81 patched-labelled), with 40 expected-origin primary boundaries. Each original full study reviewed 119 cases; the now-automatic Next.js case is excluded from the revised projection. Hosted models have one saved pass; Qwen3 has three.

Mode / reviewer	Vuln recall / 601	Origin recall / 601	Patched FPR / 599	Reviews / 1200
LLM OFF	564 (93.84%)	559 (93.01%)	32 (5.34%)	118
Qwen3-8B (r1)	594 (98.84%)	580 (96.51%)	81 (13.52%)	3
Qwen3-8B (r2)	594 (98.84%)	580 (96.51%)	80 (13.36%)	3
Qwen3-8B (r3)	594 (98.84%)	580 (96.51%)	81 (13.52%)	3
GLM-5	593 (98.67%)	580 (96.51%)	33 (5.51%)	47
Gemini Flash-Lite	593 (98.67%)	580 (96.51%)	34 (5.68%)	41
Gemini Pro	592 (98.50%)	579 (96.34%)	35 (5.84%)	44

Qwen review raises recall but substantially raises false alerts; seven vulnerable-labelled cases are dismissed per pass after excluding Next.js. GLM/Flash-Lite dismiss two each; Pro dismisses one. PATCHED applies to the reviewed advisory only. Retaining scoped dismissals leaves 88 GLM, 87 Flash-Lite and 87 Pro cases unresolved.

Aligned decisive accuracy remains GLM 39/40, Flash-Lite 38/40 and Pro 38/38 (now two aligned abstentions). Conditional denominators do not measure overall review accuracy. DeepSeek remains incomplete at 46/119 historical reviews. Reused 12-case pilots are development evidence.

Clone-detection comparison: optional supporting result

100 positive clone-intent candidates	Any reference linkage	Correct-origin linkage
ProvTrail hash + region retrieval	100/100	99/100
jscpd near-miss pooled scan	85/100	85/100
jscpd near-miss known source-pair scan	89/100	Known source pair provided

This measures positive-only source-link sensitivity, not vulnerability classification, precision or false-positive rate. Type 3/4 labels describe generation intent and do not establish semantic-only clone categories. jscpd was faster in the single local timing observation; do not use this as a controlled throughput comparison.

Evidence: eval/comparison_raw/hash-rule-summary-v1/llm-review/summary.json; original reviews preserved under eval/frozen/. Clone sensitivity: docs/jscpd-clone-pilot.md.

Claims, limits and evidence map

Suggested report structure and wording

Findings section: claims supported by these runs

- 1. **Known-origin code reuse:** corrected replay gives automatic correct-origin recall of 100% for release-source targets and 86.05% for transformed candidates; combined patched false-alert rate is 5.34%, with 9.83% abstention.
- 2. **Complementary tool coverage:** the tested dependency scanners recognize all declared vulnerable-version controls, while ProvTrail recognizes the corresponding exact/renamed implementations without source-package declarations.
- 3. **Component contribution:** hashing and contrastive verification improve detection/attribution or reduce review burden. Containment can be disabled without observed aggregate detection loss in these workloads.
- 4. **Parameter tradeoffs:** K5/B10 preserves shortlisted evaluation quality; R64 exchanges attribution quality for lower GPU time. S0.80 does not provide an unqualified evaluation improvement.
- 5. **Review remains a cost:** report manual queues and conflicting advisory boundaries alongside recall. LLM confirmation trades recall, false alerts and false dismissals.

Limits to state explicitly

Expected origins remain in the reference index; the cohorts have been inspected during development. The 30/70 grouped split is retrospective. Tier 1 advisory/source validity differs from stricter executable security-boundary validation. The older cumulative v43 pool is not the final refreshed active 600+600 cohort. Transformation admissions rely on recorded preservation evidence; blanket Type 3/4 or full semantic-equivalence claims are unsupported.

Patched labels apply to selected fixes, not global absence of vulnerabilities. The ten-advisory tool study is small, correlated and limited to JS/TS npm fixtures with bounded context. SAST outcomes depend on rule/model/context coverage. SCA empty-inventory results are expected coverage boundaries. ProvTrail depends on reference coverage and does not guarantee exploitability.

Evidence locations to cite in the report

Evidence group	Location under the repository
Inputs / split / model / index	eval/frozen/experiment-active-v2/manifest.json
Corrected quality / review projections	eval/comparison_raw/hash-rule-summary-v1/
Final operating point / components	eval/frozen/active-component-ablation-gpu-v1/combined/
CPU sweep and selected evaluation	eval/frozen/active-tuning-v2/ and active-evaluation-shortlist-v2/
GPU parameter validation	eval/frozen/active-shortlist-gpu-v1/combined/
Containment designed test	eval/frozen/containment-targeted-100-gpu-v1/combined/
Current SAST / metadata / SCA	eval/comparison_raw/sast-ten-v1/, sast-ten-dependencies-v1/, sca-copy-v1/
Active cohort admission/provenance	eval/active/README.md; eval/tier2/VALIDATION.md

Corrected figures are derived quality results, not a fresh end-to-end run. Timings, costs and repeated-decision checks belong to the original code. A fresh revised baseline needs a new compatible freeze. Original reports are preserved; the recomputed summary and input hashes identify this revision.

CPU tuning grid (1/2)

All 38 settings | Tier 2 tuning: 91 vulnerable + 87 patched | Single-pass CPU times

Corrected Tier 1 tuning quality is identical across all settings: 90/90 correct-origin detections, 6/91 patched alerts and 0/181 reviews. Tier 2 rows below are unchanged by the hash rule. Each row is independent, including joint K/budget and edit/margin combinations.

#	K	B	R	V	E	M	S	T	Origin /91	FP /87	Review /178	CPU sec
1	10	10	96	3	0.90	0.10	0.70	0.70	80	6	35	1484
2	1	5	96	3	0.90	0.10	0.70	0.70	74	3	33	1439
3	1	10	96	3	0.90	0.10	0.70	0.70	74	3	43	1453
4	1	20	96	3	0.90	0.10	0.70	0.70	75	3	39	1335
5	5	5	96	3	0.90	0.10	0.70	0.70	72	5	31	1365
6	5	10	96	3	0.90	0.10	0.70	0.70	81	6	36	1357
7	5	20	96	3	0.90	0.10	0.70	0.70	81	6	52	1263
8	10	5	96	3	0.90	0.10	0.70	0.70	73	5	34	1276
9	10	20	96	3	0.90	0.10	0.70	0.70	81	6	48	1304
10	20	5	96	3	0.90	0.10	0.70	0.70	73	5	34	1283
11	20	10	96	3	0.90	0.10	0.70	0.70	80	6	34	1389
12	20	20	96	3	0.90	0.10	0.70	0.70	81	6	46	1486
13	10	10	96	3	0.80	0.05	0.70	0.70	82	13	27	1444
14	10	10	96	3	0.80	0.10	0.70	0.70	80	8	31	1444
15	10	10	96	3	0.80	0.15	0.70	0.70	78	8	31	1441
16	10	10	96	3	0.80	0.20	0.70	0.70	70	8	35	1444
17	10	10	96	3	0.85	0.05	0.70	0.70	81	11	31	1269
18	10	10	96	3	0.85	0.10	0.70	0.70	80	6	35	1313
19	10	10	96	3	0.85	0.15	0.70	0.70	78	6	35	1262

K = retrieved origin limit; B = verification candidate budget; R = candidate-region cap; V = verification regions per pair; E = minimum edit-side score; M = edit margin; S/T = structure/token thresholds. Retrieval threshold is 0 throughout. Row 1 is the baseline K10/B10/R96/V3, E0.90/M0.10/S0.70/T0.70.

These are tuning outcomes, not evaluation accuracy. CPU times exclude setup and are single-pass observations sensitive to system load and warmup. The GPU shortlist on page 3 supplies the stronger repeated timing comparison.

Evidence: eval/comparison_raw/hash-rule-summary-v1/active-tuning-v2/summary.json. Quality recomputed from saved rows; CPU times remain historical.

CPU tuning grid (2/2)

All 38 settings | Tier 2 tuning: 91 vulnerable + 87 patched | Single-pass CPU times

Corrected Tier 1 tuning quality is identical across all settings: 90/90 correct-origin detections, 6/91 patched alerts and 0/181 reviews. Tier 2 rows below are unchanged by the hash rule. Each row is independent, including joint K/budget and edit/margin combinations.

#	K	B	R	V	E	M	S	T	Origin /91	FP /87	Review /178	CPU sec
20	10	10	96	3	0.85	0.20	0.70	0.70	70	6	40	1407
21	10	10	96	3	0.90	0.05	0.70	0.70	81	11	31	1247
22	10	10	96	3	0.90	0.15	0.70	0.70	78	6	36	1302
23	10	10	96	3	0.90	0.20	0.70	0.70	70	6	41	1292
24	10	10	96	3	0.95	0.05	0.70	0.70	79	7	37	1306
25	10	10	96	3	0.95	0.10	0.70	0.70	79	5	37	1242
26	10	10	96	3	0.95	0.15	0.70	0.70	77	5	40	1577
27	10	10	96	3	0.95	0.20	0.70	0.70	69	5	46	1620
28	10	10	96	3	0.90	0.10	0.60	0.70	80	6	37	1613
29	10	10	96	3	0.90	0.10	0.80	0.70	80	5	28	1362
30	10	10	96	3	0.90	0.10	0.70	0.60	80	6	42	1310
31	10	10	96	3	0.90	0.10	0.70	0.80	79	5	27	1631
32	10	10	16	3	0.90	0.10	0.70	0.70	72	3	50	398
33	10	10	32	3	0.90	0.10	0.70	0.70	73	4	35	583
34	10	10	64	3	0.90	0.10	0.70	0.70	79	6	35	946
35	10	10	192	3	0.90	0.10	0.70	0.70	80	6	32	1718
36	10	10	96	1	0.90	0.10	0.70	0.70	79	6	35	1248
37	10	10	96	2	0.90	0.10	0.70	0.70	80	6	35	1619
38	10	10	96	5	0.90	0.10	0.70	0.70	80	6	34	1279

K = retrieved origin limit; B = verification candidate budget; R = candidate-region cap; V = verification regions per pair; E = minimum edit-side score; M = edit margin; S/T = structure/token thresholds. Retrieval threshold is 0 throughout. Row 1 is the baseline K10/B10/R96/V3, E0.90/M0.10/S0.70/T0.70.

These are tuning outcomes, not evaluation accuracy. CPU times exclude setup and are single-pass observations sensitive to system load and warmup. The GPU shortlist on page 3 supplies the stronger repeated timing comparison.

Evidence: eval/comparison_raw/hash-rule-summary-v1/active-tuning-v2/summary.json. Quality recomputed from saved rows; CPU times remain historical.